

File number: DOS-2019-04221

Subject: Complaint regarding a late and incomplete response to a right of access (Articles 15 and 12 of the GDPR) as well as a failure to comply with the security obligation (Article 32 of the GDPR) and the obligation to notify a data breach to the data protection authority (Article 33 of the GDPR)

The Contentious Chamber of the Data Protection Authority, composed of Mr. Hielke HIJMANS, president sitting alone;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter referred to as "GDPR";

Considering the Law of December 3, 2017, establishing the Data Protection Authority (hereinafter "LCA");

Considering the internal regulations as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents in the file;

Has made the following decision regarding:

The complainant:

X, hereinafter referred to as "the complainant";

The defendant: S.A. D, hereinafter referred to as "the defendant."

1 The new internal regulations of the DPA, following the amendments made by the Law of December 25, 2023, amending the Law of December 3, 2017, establishing the Data Protection Authority (LCA), came into effect on June 1, 2024. In accordance with Article 56 of the Law of December 25, 2023, it applies only to complaints, mediation files, requests, inspections, and procedures before the Contentious Chamber initiated from that date: <https://www.autoriteprotectiondonnees.be/publications/reglement-d-ordre-interieur-de-l-autorite-de-protection-des-donnees.pdf> Files initiated before June 1, 2024 [as in this case] are subject to the provisions of the LCA not amended by the Law of December 25, 2023 and the internal regulations as they existed before that date.

Decision on the merits 43/2025 — 2/30

I. Facts and Procedure

1.

On February 6, 2020, the complainant filed a complaint with the Data Protection Authority (DPA) against the defendant.

2.

The facts underlying the complaint can be summarized as follows.

3.

The complainant is insured with the defendant.

4.

The complainant reports that on May 17, 2019, he was informed by the defendant that a termination was made to the insurance contract binding them. Following this termination, the complainant received, by mail dated June 19, 2019, a claims certificate issued on June 18, 2019, relating not to his own claims but mentioning claims of another insured of the defendant, Mrs. (...) (hereinafter referred to as Mrs. W.).

5.

On August 11, 2019, the complainant sent an email to 11 recipients in the context of the dispute he has with the defendant following the unilateral termination of his contract mentioned above. Among the recipients are the following two addresses of the defendant: "feedback@ « ... » .be" and "info.claims@ « .. » .be". In this 4-page A4 email addressing various grievances that the complainant raises against the defendant and of which he informs the 9 other recipients, the complainant mentions in two lines the

following:

"Dear Sir/Madam of the claims department at D., (...). Could you provide me with all documents (internal notes, ...) concerning me (see GDPR)?"

6.

It should be noted that while the parties will conclude (see *infra*) on this email and its qualification or not as a request for access within the meaning of Article 15 of the GDPR (see *infra*), this email of August 11, 2019, was preceded by an email of 5-6 paragraphs dated August 9, 2019, sent to various addresses of the defendant, including the already mentioned address "feedback@ « ... » .be", in which the complainant already asked, "Could you provide me with all the information in detail that you have about me, as permitted by the GDPR?"

7.

Among the recipients of the email of August 11, 2019, mentioned above, the DPA contacted the complainant on August 14, 2019, via its First Line Service (SPL) and informed him that the defendant has a period of one month, which may be extended by two months, to respond to him and that if there is no response from them within this/these deadline(s), the complainant may contact the DPA.

2 These recipients are, in addition to the defendant, the following: CLAIMS.FR@ « .. » .be (legal protection insurance), OMBUDSMAN (being the Insurance Ombudsman), Mr. RD, info@ « .. » .be (the Financial Services and Markets Authority), the Data Protection Authority (DPA via the "contact" address), Mr. RW from another insurance company, and a consumer association.

Decision on the Merits 43/2025 — 3/30

8.

On November 6, 2019, the complainant reported to the DPA that he had, as mentioned in point 4 above, received on June 19, 2019, a claims history certificate related to another insured party (containing a number of personal data concerning her), Mrs. W.

9.

It appears from the file that on January 15, 2020, the complainant sent an email of formal notice to the CEO of the defendant in which he reiterated the multiple grievances he had against her, including the one regarding his requests of August 9 and 11, 2019, which remained unanswered. He stated in this regard: "I have requested, as permitted by the GDPR, all the data in your possession concerning me in the smallest details, as well as the telephone recordings since 09/08/2019. You have already committed an infringement by not responding to my request."

10.

On January 21, 2020, the defendant responded to the complainant as follows:

"Regarding your request for access to your personal data under the GDPR and the recordings of conversations with our employees:

We are in the process of gathering the requested information and will send it to you without delay. We were unable to respond to you immediately on this point after your initial request because you did not attach a copy of your identity card to justify your identity as we require on our website for security reasons. However, we will respond to you within the one-month timeframe from January 15, 2020, and we exempt you from sending a copy of your identity card as your identity is now sufficiently established in our eyes."

11.

In the same letter dated January 21, 2020, the defendant also indicated that "regarding Mrs. W., it is possible that due to a coding error, you received a claims history certificate concerning a third party unrelated to you; we apologize for this if applicable."

12.

As of January 22, 2020, the complainant informed the DPA of his intention to file a complaint against the defendant, as the responses provided by the latter in her letter of January 21 did not, in his opinion, remedy her failure to respond to his access request of August 11, 2019. The complainant also expressed surprise at the terse response given by the defendant regarding the sending of data of a third insured party (point 11).

3 It is the Contentious Chamber that emphasizes this.

4 It is the Contentious Chamber that emphasizes this.

Decision on the Merits 43/2025 — 4/30

13.

On February 6, 2020, the complainant filed his complaint with the DPA as mentioned in point 1. In it, the complainant reiterated the grievances already cited in his letter of January 22, 2020 (point 12), stemming from the lack of response within the timeframe to his access request of August 11, 2019, and the sending of data relating to a third party indicative of insufficient security measures. He also denounced the fact that in response to his access request, his data was sent to him by registered mail, received on January 23, 2020, the envelope of which was open upon receipt. He indicated that the defendant was unable, in response to his inquiry regarding this on January 23, 2020, to inform him how many pages were contained in her sending to allow him to ensure that no pages had been lost or stolen during the opening of his mail. The complainant also accused the defendant of having deleted his claims history data recorded in the CarAttest database. Finally, he also denounced having received on March 17 and 19, 2020, 3 direct marketing emails "from D. by company Z." even though he had never registered on this site.

14.

On March 2, 2020, the complaint was declared admissible by the SPL of the DPA based on Articles 58 and 60 of the LCA, and the complaint was transmitted to the Contentious Chamber pursuant to Article 62, § 1 of the LCA.

15.

On March 31, 2020, in accordance with Article 96, § 1 of the LCA, the request from the Contentious Chamber to conduct an investigation was forwarded to the Inspection Service (SI), along with the complaint and the inventory of documents.

16.

On June 15, 2020, the investigation by the SI was concluded, the report was attached to the file, and it was transmitted by the general inspector to the President of the Contentious Chamber (Article 91, § 1 and § 2 of the LCA). The investigation report contains the following findings:

-

Finding 1: By failing to respond to the complainant's access request of August 11, 2019, within the one-month timeframe, the defendant did not comply with Articles 12.3 and 15 of the GDPR.

-

Finding 2: The defendant was guilty of a data breach and a failure to meet her security obligation (Article 32 of the GDPR) by communicating by letter dated June 18, 2019, claims history data of another client to the complainant. The SI identified that this error resulted from the way the automatic generation system for claims files was designed by the defendant.

-

Finding 3: The defendant did not notify the data breach referred to in Finding 2 to the DPA in violation of Article 33 of the GDPR.

17.

It should be noted that in the questions he addressed to the defendant on April 14, 2020, the SI noted that the complainant accused the defendant of having deleted his data.

Decision on the merits 43/2025 — 5/30

of claims recorded in the CarAttest database. It also questions the complainant about the receipt of 3 direct marketing emails on March 17 and 19, 2020, "from D. by the company Z." while the complainant never registered on this site (point 13). In its response dated April 30, 2020, the defendant informs the SI that the data related to the complainant's claims were not communicated to CarAttest in the absence of a legal obligation in this regard. In any case, this data was not deleted by CarAttest at the request of the defendant since insurers have no legitimacy to request its deletion. Regarding the marketing emails, the defendant states that it did not communicate the complainant's data to the company that would be the data controller concerning the said emails sent. The defendant indicates that it has no connection with this company. The Contentious Chamber notes that following the receipt of its responses, the SI did not further investigate these aspects and did not find any breach in this

regard on the part of the defendant.

18.

On September 21, 2020, the Contentious Chamber decides, pursuant to Article 95, § 1, 1° and Article 98 of the LCA, that the case can be addressed on the merits. On the same date, the concerned parties are informed by registered mail of the provisions as set out in Article 95, § 2 and Article 98 of the LCA. They are also informed, pursuant to Article 99 of the LCA, of the deadlines for submitting their conclusions regarding the breaches of the GDPR resulting from the complaint and the SI's report. The deadline for receiving the defendant's response conclusions is set for November 2, 2020, for the complainant's reply conclusions on November 25, 2020, and for the defendant's reply conclusions on December 18, 2020.

19.

On December 4, 2020, a copy of the file (Art. 95, §2, 3° LCA) is sent to the defendant.

20. On November 2, 2020, the Contentious Chamber receives the defendant's response conclusions.

-

Regarding finding 1: the defendant denies any violation of Article 12.3 as well as Article 15 of the GDPR. The defendant argues, supported by various reasons that will be discussed further in this decision, that the email from the complainant dated August 11, 2019, did not constitute a request to exercise his right of access. It adds that in response to the complainant's email of January 15, 2020, in which the complainant made a valid access request, it provided the complainant with a copy of the requested data as early as January 21, 2020, just a week after the request was made.

-

Regarding findings 2 and 3: the defendant does not contest that the disclosure of certain non-sensitive personal data of Ms. W. to the complainant constitutes a data breach. However, it denies any necessity to notify the APD in execution of Article 33 of the GDPR given the absence of risk to the rights and freedoms of Ms. W.

Consequently, the defendant requests the Contentious Chamber to find the absence of violation of Articles 12, 15, and 33 of the GDPR and to pseudonymize the decision it will adopt.

21.

On November 25, 2020, the Contentious Chamber receives the complainant's reply conclusions. The complainant argues that his request of August 11, 2019, should, from that date, be considered a valid access request. He adds that it was preceded by an explicit request on August 9, 2019. By only responding to his requests on January 21, 2020, the defendant violated Article 12.3 of the GDPR. He also claims not to have received all the data processed concerning him. The complainant further denounces a security breach resulting from the absence of a request for his identity card to follow up on his access request. Finally, the complainant raises a series of grievances and new requests against the defendant, not covered by his complaint, unrelated to the facts following it, and some unrelated to any issue concerning the application of the GDPR. The Contentious Chamber will return to this later in the decision.

22.

On December 18, 2020, the Contentious Chamber receives the defendant's reply conclusions. The latter emphasizes that among the twenty or so requests made by the complainant in his various letters and conclusions, only some have a more or less close link with the protection of personal data. The defendant indicates that it does not contest the validity and relevance of all these requests as they are all unfounded, inadmissible, already resolved before another authority, or not attributable to the defendant and in any case unrelated to the present file.

As already indicated, the Contentious Chamber will return to this later in the decision.

23.

At the end of the schedule for exchanging conclusions, the Contentious Chamber was not able to adopt a decision as quickly as it would have liked due to insufficient resources—particularly in personnel—given the volume of complaints it was receiving. Nevertheless, the complainant regularly inquired of the Contentious Chamber about the timeframe within which it could adopt a decision regarding his complaint; a complaint which he has always confirmed, even in 2024, that he intended to maintain.

II. Motivation

II.1. Regarding the referral to the Contentious Chamber

24.

The Contentious Chamber recalls that its referral is defined based on the subject of the complaint filed, which may be broadened in support of the findings of the SI when it is seized. It adds that it may carry out certain investigations related to the grievances it is seized with in the context, for example, of its duty of diligence.

25.

In this case, the Contentious Chamber believes it does not need to exercise this prerogative to adopt a reasoned decision regarding the grievances raised by the complaint of February 6, 2020, filed by the complainant as investigated by the SI, and it adheres to the scope of its referral as defined by its letter of September 21, 2020, and the SI's investigation report.

26.

Consequently, the present decision of the Contentious Chamber will determine whether, as raised by the SI, the defendant has indeed committed

-

a violation of Articles 12.3 and 15 of the GDPR concerning the request made by the complainant on August 9 and 11, 2019 (Title II.2),

-

a violation of Article 32 of the GDPR regarding the system for extracting claims files by the insured (Title II.3), and

-

a violation of Article 33 of the GDPR regarding the absence of notification to the APD of the data breach that occurred during the sending to the complainant of a claims file related to another insured (Title II.4).

It will also address the grievances arising from the deletion of the complainant's claims data from the CarAttest database and the sending of direct marketing emails (see point 17 above).

All other grievances developed by the complainant, particularly through his reply conclusions, especially those not related to the processing of personal data, do not fall within the referral of the Contentious Chamber, notwithstanding the fact that the defendant has taken the trouble to respond to some of them.

II.2. Regarding the alleged violation of Articles 12.3 and 15 of the GDPR

II.2.1. The SI's viewpoint

27.

As mentioned in the procedural background, the SI notes that the defendant indicated during the investigation that the complainant's request of August 11, 2019, escaped its attention and that it had not identified it as a request for access rights within the meaning of Article 15 of the GDPR. The SI concludes that the defendant violated Articles 12.3 and 15 of the GDPR, not without noting that a response was provided to the request on January 21, 2020, following the complainant's reminder of January 15, 2020. The SI further considers that the fact that the complainant's access request of August 11, 2019, consists of a sentence included in the middle of a 4-page email stating numerous grievances—furthermore very diverse—constitutes a circumstance it qualifies as "mitigating" for the defendant.

II.2.2. The parties' viewpoints

The complainant

28.

The complainant states that his email of August 11, 2019, allows the various individuals addressed to have a summary of the defendant's incompetencies in the field of insurance and in the management of personal data. He specifies that the feedback department contacted by phone referred him to the claims department, to which he also sent his email. This request undoubtedly constitutes a request for access within the meaning of Article 15 of the GDPR, according to him.

29.

The complainant recalls that he had explicitly made a similar request by email on August 9, 2019, also addressed to the address feedback@ “..”.be in these terms: "Could you provide me with all the information in the slightest detail that you have about me, as permitted by the GDPR" (see above point 6).

30. The complainant notes that the justification given at the time of the events for the absence of a response to his request was, as formulated in the defendant's email of January 21, 2020, the fact that he had not attached a copy of his identity card to justify his identity. In this regard, the complainant indicates that he was surprised by this as of February 10, 2020, since the email address from which he had made his request had been regularly used by the defendant in its contacts with him since 2008. This address was noted in a contract proposal document from 2016 issued by the defendant and was therefore clearly known to it. The management of his claims from 2017, 2018, and 2019 had also been conducted using this address, and his annual invoices were also sent solely by email to this address.

31. Finally, as he indicated to the APD as of February 10, 2020, the complainant believes that the data concerning him that was communicated in response to his access request was incomplete. He points out that he received a more comprehensive file from his legal protection insurance company to which he had made a similar request. As already mentioned, in his email of February 10, 2020, the complainant also indicates both

Decision on the Merits 43/2025 — 9/30

to the defendant that to the APD it suspects the defendant has a file concerning him that is not included in what has been communicated to him.

The Defendant

32. The defendant argues that the email dated August 11, 2019, from the complainant does not contain a request to exercise his right of access within the meaning of Article 15 of the GDPR, such request not being validly formulated or addressed through one of the many channels made available to data subjects to facilitate the exercise of their rights. Consequently, the defendant believes that it was not obliged to respond within the timeframe of Article 12.3 of the GDPR. Therefore, it has not committed any violation of Articles 12.3 and 15 of the GDPR.

33. In this regard, the defendant notes that:

- The complainant's request was not addressed to the addresses provided for this purpose since it was sent to the addresses “feedback@ « .. » .be” and “info.claims@ « .. » .be” of the defendant, which are generic email boxes not intended to receive requests for the exercise of rights that data subjects derive from the GDPR. The defendant emphasizes that the page dedicated to privacy information on its website provides the contact details of its Data Protection Officer (DPO) to receive such requests and that the email address of the latter is also communicated in the following documents: the data privacy statement, the privacy policy statement, the cookie statement, as well as in the specific terms of the insurance contract. Other channels are also available to data subjects, such as sending postal mail, a telephone number, or even visiting “in-store” to make their request.
- The complainant's request, consisting of a single sentence, was buried in a substantial email (4 A4 pages), lost amid a long list of varied grievances.
- The complainant's intention to exercise one of the rights conferred by the GDPR was not evident from the subject of his email, which was formulated as follows: “Subject: Request for an urgent response from D.”
- This request, unlike the other grievances or requests, was not particularly identified and was not included in the summary list of requests with which the complainant concluded his email; requests that he attributed this time to an identifiable recipient among the recipients of his email (of which only two addresses concerned the defendant).

Decision on the Merits 43/2025 — 10/30

-

The scope of the request was not defined (“Could you provide me with all documents (internal notes, etc.) concerning me (see GDPR)?”) and did not allow the defendant to respond.

-

The complainant did not specify the manner in which he wished to obtain communication of his data.

34. The defendant emphasizes the mitigating circumstances noted by the SI and recalled in point 27 above.

II.2.3. Assessment by the Contentious Chamber

35. Under Article 15.1 of the GDPR, the data subject has the right to obtain from the data controller confirmation as to whether or not personal data concerning him or her is being processed (1st aspect of the right of access).

36. When this is the case, the data subject has the right to obtain a series of information listed in Article 15.1 a) - h) and 15.2 of the GDPR relating to the processed data as well as access to it (2nd aspect of the right of access)⁸.

37. The GDPR also provides in Article 15.3 that the data controller shall provide a copy of the personal data to the data subject. The provision of a copy is the primary means of granting access to the processed data.

38. The data subject is not required to justify why he or she requests access to his or her personal data⁹.

39. Article 15 of the GDPR must necessarily be read and applied in conjunction with Article 12 of the GDPR concerning the modalities for exercising the rights of data subjects.

⁸ This includes: a) the purposes of the processing; b) the categories of personal data concerned; c) the recipients or categories of recipients to whom the personal data have been or will be disclosed, in particular recipients established in third countries or international organizations; d) where possible, the envisaged retention period for the personal data or, where that is not possible, the criteria used to determine that period; e) the existence of the right to request from the data controller the rectification or erasure of personal data, or a restriction of processing of personal data concerning the data subject, or the right to object to such processing; f) the right to lodge a complaint with a supervisory authority; g) where the personal data are not collected from the data subject, any available information as to their source; h) the existence of automated decision-making, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject. Under Article 15.2 of the GDPR, the data subject also has the right to be informed of the appropriate safeguards under Article 46 in the event of the transfer of his or her data to a third country outside the European Economic Area (EEA) or to an international organization.

⁹ See CJEU, judgment of October 26, 2023, FT, C-307/22, § 35-38. “38. It must be noted that neither the wording of Article 12, paragraph 5, of the GDPR nor that of Article 15, paragraphs 1 and 3, of this regulation conditions the provision, free of charge, of a first copy of the personal data on the invocation, by these persons, of a reason justifying their requests. These provisions therefore do not give the data controller the possibility to require reasons for the access request made by the data subject.” The CJEU further adds that the reasons for which the person wishes to access the data concerning him or her are not limited to those set out in recital 63 of the GDPR.

Decision on the merits 43/2025 — 11/30

a. Thus, under Article 12.2 of the GDPR, the data controller is required to facilitate the exercise of the rights conferred to the data subject under Articles 15 to 22 of the GDPR.

b. Under Article 12.3 of the GDPR, “the data controller provides the data subject with information on the measures taken in response to a request made under Articles 15 to 22, without undue delay and in any event within one month of receiving the request. If necessary, this period may be extended by two months, taking into account the complexity and number of requests. The data controller informs the data subject of this extension and the reasons for the delay within one month of receiving the request. When the data subject submits their request in electronic form, the information is provided electronically where possible, unless the data subject requests otherwise.”

40. The Contentious Chamber considers, in support of the following reasoning, that the request made by the complainant in their email of August 11, 2019, constitutes a request to exercise their right of access within the meaning of Article 15 of the GDPR.¹⁰

41. The Contentious Chamber notes at the outset that it was only before the Data Protection Authority (DPA) that the defendant indicated that it had not identified the complainant's request as a request for

access to justify the lack of response within the timeframe of Article 12.3 of the GDPR (see below) that was being criticized. In its letter of January 21, 2020, the defendant indeed states that it did not respond to the complainant because the complainant had not attached their identity card to their request (point 10).

42. Even if this request is, as the defendant points out, somewhat lost in an email related to a dispute between the complainant and the defendant regarding the latter's insurance activities and the contract between them, this sole circumstance does not disqualify it. The GDPR does not provide for any formal requirement for individuals requesting access to their data. To submit a request for access, it is sufficient for the applicants to specify that they wish to know the personal data concerning them processed by the data controller without even having to explicitly refer to the GDPR.¹¹ Therefore, the data controller cannot refuse to respond to a request by invoking the absence of a specific reference to the right of access or to the GDPR, nor a fortiori to the absence of a reference to Article 15. It cannot rely on

10 The Contentious Chamber similarly concludes regarding the request of August 9. Since this was not debated by the parties, the Contentious Chamber focused on qualifying the request made by the complainant on August 11, 2019.

11 European Data Protection Board (EDPB), Guidelines 01/2022 of March 28, 2023 on the rights of data subjects — Right of access, point 50.

Decision on the Merits 43/2025 — 12/30

the subject of the email containing the request, which did not refer to the GDPR or a request for access.

43. In this case, the Contentious Chamber is of the opinion that the terms used by the complainant in his email of August 11, 2019, were sufficient for the defendant to identify it as a request to exercise the right of access. Furthermore, the complainant expressly referred to the GDPR. The Contentious Chamber notes abundantly that the wording in this email is not very different from that used in the reminder of January 21, 2020, which was considered by the defendant as a request for access.

44. The Contentious Chamber decides that it is therefore in vain that the defendant attempts to hide behind the fact that the subject of the complainant's email did not state that it was a request for the right of access or that his request was not included in what the defendant qualifies as a "summary list of his requests" at the end of the email.

45. The complainant having made a request to exercise his right of access within the meaning of Article 15 of the GDPR, the above-mentioned Article 12.2 of the GDPR is applicable. Regarding the remaining elements invoked by the defendant in support of its defense that the complainant's request did not constitute a request for access (point 33), the Contentious Chamber rejects them one by one for the reasons set out below. It concludes that none of these elements are relevant in light of Article 15 of the GDPR. They appear, in view of the initial motivation contained in the letter of January 21, 2020 (points 6 and 41), to be vain attempts at post hoc justification. These elements invoked by the defendant are in any case contrary to what is expected of it in fulfilling its obligation to facilitate the rights of the data subject (Article 12.2 of the GDPR).

-

Regarding the copy of the complainant's identity card, it was in any case the responsibility of the defendant, assuming it was authorized to request such a copy (see below), to contact the complainant to obtain it instead of ignoring his request on the grounds that it was not provided to him.

-

Regarding the scope of the complainant's request, the data controller (here the defendant) cannot ignore a request for access on the grounds that it does not

12 For reference, the complainant made the following request: "Madam, Sir from the claims department at D, (...). Could you provide me with all the documents (internal notes, ...) concerning me (see the GDPR)?"

13 For reference, the complainant formulates his reminder as follows: "I have requested, as permitted by the GDPR, all the data in our possession concerning me in detail and also the telephone recordings since 09/08/2019."

would not be sufficiently precise. Here again, it was up to the defendant to contact the complainant to clarify, if necessary, the extent of their request.

-

Regarding the modalities of communication of personal data concerning the complainant that the complainant had not (sufficiently) specified, Article 15.3 of the GDPR provides - as has been recalled - that the data controller must provide a copy of the personal data to the data subject. In a judgment C-487/21 of May 4, 2023, the Court of Justice of the European Union (CJEU) held that Article 15.3 of the GDPR must be interpreted in such a way that "the right to obtain from the data controller a copy of the personal data undergoing processing implies that a faithful and intelligible reproduction of all such data is provided to the data subject. This right entails the right to obtain copies of extracts from documents or even entire documents or extracts from databases that contain, among other things, said data, if the provision of such a copy is essential to enable the data subject to effectively exercise the rights conferred on them by this regulation, it being emphasized that account must be taken, in this regard, of the rights and freedoms of others." If this judgment from 2023 is subsequent to the facts, it remains that in case of doubt and notwithstanding the clarity of the text which explicitly mentions the copy of personal data, it was once again up to the defendant to contact the complainant to ask, if necessary, the manner in which they wished to access their personal data.

46. Regarding the calculation of the one-month period within which the data controller must provide information on the follow-up to a request for the exercise of rights (such as the access request in this case) in execution of Article 12.3 of the GDPR, this calculation must be carried out in accordance with European Union law. Furthermore, it is the date of receipt of the request by the data controller that triggers this period. In other words,

14 In its Guidelines on the right of access, the EDPS specifies that the data controller who processes a large amount of information relating to the data subject may ask the latter to specify the information or processing to which the request relates before the information is provided (see Recital 63 of the GDPR). It is important to emphasize that the request for clarification is not intended to limit the response to the access request and is not used to conceal information about the data or processing concerning the data subject. If the data subject, who has been invited to clarify the scope of their request, confirms the search for all personal data concerning them, the data controller must, of course, provide them in full. In any case, the data controller should always be able to demonstrate that the manner of processing the request aims to give the broadest effect to the right of access and that it complies with its obligation to facilitate the exercise of the rights of data subjects (Article 12, paragraph 2, of the GDPR) (point 35 of the Guidelines).

15 CJEU, judgment of May 4, 2023, Österreichische Datenschutzbehörde and CRIF GmbH, C-487/21, ECLI:EU:C:2023:369, § 45.

16 The deadline for responding to an access request must be calculated in accordance with Council Regulation (EEC, Euratom) No. 1182/71 of June 3, 1971, laying down rules applicable to time limits, dates, and terms), OJ L 124/1.

17 This period may be suspended when the data controller must communicate with the requester due to uncertainty regarding their identity (is it indeed the data subject as defined in Article 4.1 of the GDPR?). The period may be suspended until the data controller has obtained from the data subject the necessary information, provided that the data controller has requested additional information without undue delay.

The one-month period begins to run when the data controller has received a request, and it is not necessary in this regard that they have actually acknowledged it.¹⁸

47. The receipt by the data controller also implies that the request has reached them through one of their relevant channels in the sense that will be specified below. Data controllers are thus encouraged to provide the most appropriate and user-friendly communication channels, in accordance with Articles 12.2 (obligation to facilitate the exercise of rights) and 25 of the GDPR, in order to enable the data subject to submit an effective request. This may include, for example, communication details of the

data controller provided in their communications directly addressed to data subjects or contact details publicly provided by the data controller, for instance in their privacy policy or in other mandatory legal notices of the data controller (e.g., the contact information of the owner or the company on a website).¹⁹ It is not contested in this regard that the defendant has established several communication channels, including a DPO email address as outlined in their conclusions (point 33).

48. Nevertheless, the Dispute Chamber considers that if a data subject submits a request using a communication channel provided by the data controller but which is different from the one indicated as preferable, this request should generally still be taken into account, and the data controller must process it accordingly. Simply ignoring it is not in compliance with the obligation incumbent upon them under Article 12.2 of the GDPR mentioned above.²⁰

49. Conversely, the data controller is not obliged to respond to a request sent to a random or incorrect email address (or postal address) not directly provided by the data controller, or to a communication channel that is clearly not intended to receive requests regarding the rights of the data subject, if the data controller has provided an appropriate communication channel to the data subject.²¹

In this regard: European Data Protection Board (EDPB), Guidelines 01/2022 of March 28, 2023 on the rights of data subjects - right of access: https://www.edpb.europa.eu/system/files/2024-04/edpb_guidelines_202201_data_subject_rights_access_v2_fr.pdf (point 159). The EDPB details how to understand the modalities for exercising this right, including how the request should be formulated and to whom, as well as how the one-month period provided for in Article 12.3 should apply. This Article 12.3 is applicable for the exercise of all the rights referred to in Articles 15 to 22 of the GDPR, and these considerations apply to the case at hand, which addresses compliance with Article 12.3 of the GDPR in relation to a request for the exercise of the right to erasure provided for in Article 17 of the GDPR.

18 The European Data Protection Board (EDPB) considers it good practice for data controllers to confirm the receipt of requests in writing, for example by sending emails (or postal letters, where applicable) to the individuals who made the request, confirming that their requests have been received and that the one-month period runs from day B to day C. See the aforementioned guidelines - points 57 and 159.

19 Idem, point 53.

20 Idem, point 53.

21 Idem, point 54 and the examples.

Decision on the merits 43/2025 — 15/30

50. In this case, the Contentious Chamber notes that the complainant did not address their request to the DPO of the defendant nor use the other channels made available to data subjects specifically for exercising their rights under the GDPR. Nevertheless, the complainant sent their request to an address which they claim was provided to them as a relevant address for handling "claims" (namely, in addition to the address `feedback@ "..." .be`, to the address `info.claims@ "..." .be`). The Contentious Chamber finds that this is indeed an address provided by the data controller and is not a random address. While the email address of the "claims" department is not specified as being the one specifically designated to receive requests for the exercise of rights under the GDPR, the Contentious Chamber believes that it cannot reasonably be said that it is manifestly not intended to receive such requests.

51. A request for access is not necessarily formulated independently of any other request that the data subject may have with respect to the data controller in the context of the commercial or professional relationships they maintain. Requiring the data subject to isolate their access request in a separate email, addressed to a different recipient than the manager of their claim, for example, or to the legal department of the data controller when they are in dispute with the latter, would be entirely artificial and contrary to Article 12.2 of the GDPR already mentioned. It is also the responsibility of the data controller to train its staff so that they are able to identify a request for access rights under the GDPR, which does not exclude that the request thus identified may then be forwarded to another competent service or to the DPO when designated.

52. As necessary, the Contentious Chamber clarifies that it is up to it to consider whether, in light of the case at hand, the address should or should not be considered as "manifestly not intended to receive requests for the exercise of the rights of data subjects" and that it is not sufficient for the data controller

to qualify it as such.

53. In this case, the complainant, in addition to their sending to info.claims@ "...".be, explicitly referred to the GDPR as already mentioned.

54. In support of the above, the Contentious Chamber notes that the one-month period provided for in Article 12.3 of the GDPR began to run on August 11, 2019, the receipt of this email by the defendant at the address info.claims@ "...".be not being contested. It is also undisputed that the defendant did not respond to this request and that it was only following the complainant's reminder on January 15, 2021, that it reacted on January 21, 2020, more than 5 months after the complainant's initial request of August 11, 2019.

Decision on the merits 43/2025 — 16/30

55. The Contentious Chamber concludes that the defendant did not comply with the provisions of Articles 12.3 and 15 of the GDPR in that it did not respond to the complainant's access request of August 11, 2019, within the one-month period from its receipt.

56. Regarding the alleged incompleteness of the data ultimately received in response to the exercise of the complainant's right of access, the Contentious Chamber is unable to ascertain that all data processed by the defendant was not communicated to the complainant. The report from the SI does not contain elements in this regard. The mere circumstance that the legal insurance company may have transmitted more data to the complainant in response to the access request that he also addressed to it does not necessarily prove that what was transmitted by the defendant was incomplete.

57. In support of the above, the Contentious Chamber concludes that it is unable to ascertain a breach of Article 15.3 of the GDPR due to personal data that was not provided to the complainant by the defendant during the exercise of the latter's right of access.

58. Regarding the request for a copy of the complainant's identity card for the purpose of identifying him prior to any response to his right of access, the Contentious Chamber limits itself in this decision to the reminders that follow and the cited notes, particularly with reference to the Guidelines on the right of access of the EDPB already mentioned.

59. The EDPB considers that the use of a copy of an identity document for authentication purposes creates a risk for the security of personal data that could result in unauthorized processing of such data. As such, this practice—albeit widespread—should be considered inappropriate unless it is necessary, appropriate, and compliant with national law.

22 See in this regard Article 6.4 of the Law of July 19, 1991, on population registers, identity cards, foreigner cards, and residence documents, M.B., September 3, 1991. See also Recommendation 03/11 of May 25, 2011, from the Commission for the Protection of Privacy (CPVP) regarding the taking of copies of identity cards as well as their use and electronic reading:

<https://www.autoriteprotectiondonnees.be/publications/recommandation-n-03-2011.pdf>

Decision on the merits 43/2025 — 17/30

60. When an identity document is requested (and this is both in accordance with national law and justified and proportionate under the GDPR), the data controller must implement safeguards to prevent the unlawful processing of the identity card, its copy, and the personal data contained therein.

Notwithstanding any applicable national provisions regarding identity authentication, this may include refraining from making a copy or deleting a copy of an identity document immediately after the successful authentication of the identity of the data subject, or inviting the data subject to obscure the data on the identity card that is not necessary for identification/authentication. The EDPB recommends, as a good practice, that the data controller, after verifying the identity card, make a note indicating, for example, "the identity card has been verified" in order to avoid unnecessary copying or storage of identity card copies.²³

II.3. Regarding the alleged violation of Article 32 of the GDPR

II.3.1. The position of the SI

61. As mentioned in the procedural background, the SI concludes that there has been a data breach and a failure to comply with Article 32 of the GDPR, as the criteria for selecting claims data in the defendant's system resulted in claims of Ms. W. being erroneously linked to the complainant during the

extraction of the complainant's claims file, these criteria being insufficient to exclude this risk of error. The SI also notes the information provided by the defendant that as of June 26, 2019 (the disputed transmission dated June 18, 2019), the selection criteria of its computer program were corrected.

62. Without finding a breach in this regard, the SI also notes that the DPO of the defendant indicates that he was only informed of the case in 2020, whereas he was the DPO at the time of the events (i.e., in June 2019), as evidenced by the communication of his contact details to the APD as the DPO of the defendant registered as of May 25, 2018²⁴.

23 Points 75 to 80 of the aforementioned EDPB Guidelines on the right of access.

24 This notification follows the application of Article 37.7 of the GDPR, which states that "the data controller or the processor shall publish the contact details of the data protection officer and communicate them to the supervisory authority." Among the tasks of the data protection officer is indeed to "act as a contact point for the supervisory authority on issues relating to processing, including the prior consultation referred to in Article 36, and to consult, where appropriate, on any other matter" in accordance with Article 39.1.e) of the GDPR, as well as to cooperate with the supervisory authority (Article 39.1.d)).

Decision on the merits 43/2025 — 18/30

II.3.2. The position of the parties

The complainant

63. The Contentious Chamber notes that the complainant reported the erroneous transmission, expressing concern about the reliability of the system and the risk that data concerning him may have been improperly transmitted to third parties upon his return.

64. The complainant also denounces the fact that in response to his access request, the personal data concerning him was sent by postal mail (albeit registered) without any other security measures. He points out that the envelope arrived open. He is also surprised that no verification by copying his identity card was carried out before sending him his data.

The defendant

65. The defendant does not contest that the erroneous transmission of data relating to Ms. W. to the complainant constitutes a data breach.

66. Regarding the security measures surrounding the sending of the complainant's personal data in January 2020 in response to his access request, the defendant believes that sending by registered mail is sufficiently secure and that it was no longer necessary at that time for it to verify the identity of the complainant, as it was sufficiently established.

II.3.3. Assessment by the Contentious Chamber

67. Article 4.12 of the GDPR defines a "personal data breach" as "a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of personal data transmitted, stored, or otherwise processed, or unauthorized access to such data."

68. In this case, the Contentious Chamber finds that the sending to the complainant of a claims file containing data relating to the claims of Ms. W. constitutes a data breach within the meaning of Article 4.12 of the aforementioned GDPR. More specifically, it is an "unauthorized disclosure of personal data."

69. The Contentious Chamber indeed notes that the claims certificate²⁵ communicated to the complainant contains the following information elements:

25 The claims declaration is issued in accordance with the AR of January 16, 2002 and to be submitted to the next insurer.

Decision on the Merits 43/2025 — 19/30

-

the insurance contract number of the insured, the annual expiration date thereof, the date of the contract offer acceptance (liability coverage) and the contract end date;

-

the registration plate number of the insured vehicle and the vehicle category as well as the type of use of the vehicle (private use, professional use, or mixed use);

-
the date of the claims, the name, first name, and date of birth of the driver, as well as the amount of compensation actually paid and the status of the case closure (yes or no). A driver code is also attached to each claim, which indicates whether the driver's liability is engaged, shared, not engaged, or not yet determined.

70. The Dispute Chamber establishes that these elements of information constitute personal data within the meaning of Article 4.1 of the GDPR, which defines personal data as "any information relating to an identified or identifiable natural person." The Dispute Chamber specifies that it appears from the writings of the complainant and the defendant that the claims file sent to the complainant contains both personal data relating to the complainant (name, first name, vehicle, registration plate) and data relating to Mrs. W. (name, first name, and data relating to her claims).

71.

It is also undisputed that the defendant mistakenly transmitted the latter data (i.e., the personal data of a third party) to the complainant, whereas under the terms of his right of access, the complainant is entitled to obtain a copy of only the personal data concerning him. The personal data relating to Mrs. W. do not fall under this.

72.

There has therefore been an unauthorized disclosure of personal data by the defendant, who is thus guilty of a data breach within the meaning of Article 4.12 of the GDPR.

73.

The Dispute Chamber recalls here that pursuant to Article 32.5, any data breach that occurs must be documented. It notes that in this case, the defendant states in its response conclusions that it has documented this breach.

74.

As the SI has been able to ascertain, this data breach is a consequence of how the computer system operated at the time of the events to search for a client's claims. In this instance, the criteria for selecting claims data were based on the last 6 digits of the insured's policy (in this case XXXXXX) and not on the entirety of the 8 digits of the insured's contract (in this case YYXXXXXX). For this reason, the details of the claims generated automatically included those of contract YYXXXXXX (of the complainant) as well as those of contract ZZXXXXXX of Mrs. W.

Decision on the merits 43/2025 — 20/30

75.

Article 32.1 of the GDPR states that "taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing as well as the risks, the likelihood and severity of which vary, to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk (...)".

76.

The Disciplinary Chamber is of the opinion that providing a selection criterion of 6 digits, whereas the policy numbers contained more digits, did not constitute a sufficient selection method to avoid the risk of incorrectly attributing a claim to an insured party unrelated to it. Given that the identification of contracts possibly contained 8 digits, this risk of error appears foreseeable. This is all the more the case as the defendant indicated to the SI that the system for generating claims files was automatic. The defendant therefore did not opt for a sufficient technical measure to ensure adequate security.

77.

The Disciplinary Chamber adds that there seems to have been no verification of the file before its dispatch. The application of the four-eyes principle or at least the verification of the document—which is moreover required by law (see below)—could have allowed for the identification of the names of two distinct insured parties on the document.

78.

If the defendant indicates that following the disputed dispatch, the selection criteria of the computer program were quickly corrected, as of June 26, 2019, that only one error due to the configuration of the system is to be regretted, and that the search is now conducted on the complete nomenclature of the

client's policy number (and no longer on its last 6 digits), the Disciplinary Chamber nonetheless concludes that the defendant was guilty of a breach of Article 32 of the GDPR at the time of the facts. 79.

In light of the SI's remark regarding the DPO, the Disciplinary Chamber reminds the defendant that in accordance with Article 38.1 of the GDPR, the controller must ensure that its DPO is involved, in an appropriate and timely manner, in all issues related to the protection of personal data. This obligation implies that the DPO must indeed be informed of complaints lodged against the controller regarding the exercise of the rights of the data subjects, as was the case here, but also of security incidents affecting personal data. In the Guidelines dedicated to the DPO²⁶, the Article 29 Working Party indicated, as early as 2017, that the DPO should be considered a point of contact within the organization and expressly added that this

26 Guidelines on Data Protection Officers (DPOs), April 5, 2017, point 3.1. page 16 of the French version.

Decision on the merits 43/2025 — 21/30

implied that "the DPO should be consulted immediately when a data breach or another incident occurs"²⁷.

80. Regarding the complaint made by the complainant concerning the insufficiently secure transmission of his personal data in response to his access request, the Contentious Chamber recalls that since the communication and provision of personal data to the data subject is a processing operation, the data controller (here the defendant) is always required to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing [Articles 5.1.f), 24, and 32 of the GDPR]. This obligation applies regardless of the form in which access is provided. In the case of non-electronic transmission of data to the data subject, depending on the risks presented by the processing, the data controller may consider using registered mail or, failing that, offer the data subject the option to collect the file in person against signature directly from one of its establishments, without being able to compel them to do so.

81.

In this case, the Contentious Chamber is of the opinion that by sending a registered letter, the defendant opted for sufficiently secure communication. The Contentious Chamber finds no breach of Article 32 of the GDPR on the part of the defendant in this regard. Furthermore, the defendant cannot be held responsible for envelopes that arrive open. On the other hand, it appears to the Contentious Chamber that the data controller must be able to specify to the data subject what the content of the transmission was.

82.

Finally, regarding the complainant's grievance concerning the lack of sufficient precautions in verifying his identity in the context of his access request, the Contentious Chamber refers to what it has stated in points 58-60 above. The Contentious Chamber specifies that the provision of an identity card by the requester is neither systematically necessary, nor appropriate, nor even authorized. In this case, the Contentious Chamber is of the opinion that the defendant could conclude, given the long-standing client relationship it had with the complainant, from the request made by the latter from a regularly used email address known to the defendant, as well as the factual elements invoked by the complainant relating to his specific situation, that it was indeed the complainant making the access request. No breach of the security obligation (Article 32 of the GDPR) can be attributed to the defendant on this account.

II.4. Regarding the alleged violation of Article 33 of the GDPR

II.4.1. The view of the SI

83. The SI develops in its investigation report that the notification of a data breach is the rule and that the failure to notify "when the breach is not likely to result in a risk to the rights and freedoms of natural persons"²⁸ is the exception. The SI is of the opinion that in this case the conditions for applying this exception were not met. From the moment it is established that data relating to automobile claims of insured parties were inadvertently disclosed to other insured parties, the risk of harm as outlined in Recital 85 of the GDPR is real. The SI further adds that the defendant cannot reasonably argue that

the data breach was not structural and was merely isolated, as it resulted from the way the claims certificate generation system was designed. The SI concludes that the defendant violated Article 33 of the GDPR.

II.4.2. The views of the parties

The complainant

84. The complainant does not conclude on this alleged violation of Article 33 of the GDPR.

The defendant

85. The defendant believes it rightly considered that the data breach that occurred did not need to be notified to the APD.

86. It indicates that it conducted an assessment of the severity of the data breach according to the methodology recommended by ENISA, which concluded that the severity was low.

87.

The defendant adds that its analysis notably established the maximum extent of the incident, which was likely to recur, prior to the remediation it undertook, concerning claims research conducted for only 8 affected individuals. The defendant specifies that in this case, however, there was only one erroneous disclosure, that of data relating to Ms. W. to the complainant.

28 This is emphasized by the Contentious Chamber.

Decision on the Merits 43/2025 — 23/30

88. The defendant adds that concerning this sole victim, a limited number of personal data (name, first name, date of birth, date of the incident, and amount paid by the insurer) and non-sensitive data was disclosed to a single third party, the complainant.

II.4.3. Assessment of the Disciplinary Chamber

89. Article 33 of the GDPR states that "in the event of a personal data breach, the data controller shall notify the breach to the competent supervisory authority in accordance with Article 55, without undue delay and, where feasible, not later than 72 hours after having become aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. When the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by the reasons for the delay."²⁹

90. This notification to the data protection authority is motivated by the risks that may materialize as a result of the data breach, as notably identified in Recital 85 of the GDPR³⁰, and aims to mitigate these risks.

91. The application of Article 33 of the GDPR therefore presupposes a "data breach," the existence of which the Disciplinary Chamber has concluded in this case in paragraph 72 above.

92. Unless "the breach in question is unlikely to result in a risk to the rights and freedoms of natural persons," the notification of the said breach to the competent supervisory authority is mandatory. To rely on this exemption, the data controller must:

(1) assess the risks that the breach may entail at the moment it becomes aware of it, and

(2) conclude that there is no risk within, at most, the 72-hour period to proceed with the notification to the supervisory authority.

93. During its risk assessment, the data controller must identify the type of breach (confidentiality, integrity, availability), the source of the incident (whether the breach results from human error or is systemic, for example), and take into account the nature

29 It is the Disciplinary Chamber that emphasizes this.

30 "A personal data breach may, if timely and appropriately addressed, cause physical, material, or moral damage to the affected natural persons, such as a loss of control over their personal data or the limitation of their rights, discrimination, theft or identity fraud, financial loss, unauthorized reversal of the pseudonymization process, damage to reputation, loss of confidentiality of personal data protected by professional secrecy, or any other significant economic or social damage. Consequently, as soon as the data controller becomes aware that a personal data breach has occurred, it should notify the supervisory authority without undue delay and, where feasible, not later than 72 hours after having become aware of it, unless it can demonstrate, in accordance with the principle of accountability, that it is unlikely that the breach in question will result in a risk to the rights and freedoms of natural persons.

If such notification cannot be made within this 72-hour period, the notification should be accompanied by the reasons for the delay, and information may be provided in a staggered manner without further undue delay."

Decision on the merits 43/2025 — 24/30

of the data (are the data "public" or have they been made public, for example), their sensitivity (in the sense of Articles 9 and 10 of the GDPR but also in the sense of the Guidelines of the EDPS regarding data protection impact assessment which qualify certain data as "highly personal"³¹), the volume, and the context of the personal data concerned by the breach. The nature and role of the data controller as well as their activities may also influence the level of risk that a data breach poses to the rights and freedoms of the individuals concerned.

94. In this case, the Contentious Chamber agrees with the analysis of the SI which considers that the defendant could not reasonably conclude that the breach would not be likely to pose a risk to the rights and freedoms of the individuals concerned.

95. It appears from the defendant's conclusions and the complainant's writings that certain data in this claim report actually relate to the complainant and others relate to Mrs. W. (see above), this distinction can only be made by the complainant and the defendant. Upon reading the report, a third party could conclude that the claims and liabilities associated with it actually belong to the complainant and that the mention of Mrs. W. is erroneous, or conversely, consider that the identification data actually belong to Mrs. W. and not to the complainant, who would only be the recipient of the document without any data concerning them being included, which is not the case.

96. The Contentious Chamber further notes that while the claim report does not contain any specific categories of data within the meaning of Article 9.1 of the GDPR, it nonetheless contains information that is not accessible to the public or to third parties, which occurs in an insurance context and reveals an attribution of liability to a driver. Furthermore, this information is communicated through a document required by law (the degree of accuracy of the data is therefore even more important) which must allow the insured (in principle, the individual concerned by the data contained therein) to take out an insurance policy with a new insurer and to inform the latter of the history of claims involving their vehicle, which could have a potential financial impact on them. This history will indeed be taken into account in the risk assessment and the calculation of the insurance premium by the new insurer.

31 European Data Protection Board (EDPB), Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is "likely to result in a high risk" for the purposes of Regulation (EU) 2016/679 (initially adopted by the Article 29 Working Party, WP 248 and taken over by the EDPB), page 11 of the French version: "Beyond the provisions of the GDPR, certain categories of data may be considered as increasing the possible risk to the rights and freedoms of individuals. These personal data are considered sensitive (in the common sense of the term) to the extent that they are related to domestic and private activities (electronic communications whose confidentiality must be protected, for example), to the extent that they impact the exercise of a fundamental right (location data whose collection affects the freedom of movement, for example), or to the extent that their breach would clearly have serious implications in the daily life of the individual concerned (financial data that could be used for fraudulent payments, for example).

Decision on the Merits 43/2025 — 25/30

A significant claims history may lead to a refusal of insurance. An incomplete or erroneous history will therefore have consequences on the insurance taken out and the premium requested.

97.

Although no particular category of data within the meaning of Articles 9 or 10 of the GDPR has been affected, the data consulted contains a number of pieces of information, including contact information about individuals, and this data could be used in various ways (targeted unsolicited marketing, identity theft, etc.).

98.

With regard specifically to the complainant in this case, the reading of this certificate by the third party to whom it is addressed (i.e., a new insurance company) could thus lead to consequences, even financial harm, if their identity data were to be associated with the claims and liabilities of Ms. W.

According to the Contentious Chamber, this data related to claims and their liability can be classified as "highly personal."³²

99.

As for Ms. W., data relating to her claims, her liability, and the involvement of the defendant has, in any case, been improperly communicated to the complainant. As mentioned, this data has particular sensitivity. For the Contentious Chamber, the context recalled above in which this data is processed is sufficient to conclude that the defendant could not consider that there was no risk for Ms. W.

100.

It matters little in light of the identified risks that the data breach concerns, following the defendant's thesis (which is not the case), only a single person. The Contentious Chamber has outlined above that the complainant could also prove to be a victim of this data breach. Furthermore, the SI report identified that the source of the incident was due to the system, and the defendant could not consider the incident as necessarily isolated.

101.

The Contentious Chamber adds, as it has mentioned, that in order to conclude that there was no risk to the rights and freedoms of the individuals concerned and to decide that it was not obliged to notify the data breach to the APD, the defendant had to reach these conclusions and decisions within the 72-hour timeframe referred to in Article 33 of the GDPR and be able to demonstrate it. To this end, the Contentious Chamber recommends that this type of analysis always be dated. In this case, the analysis relied upon by the defendant is, if it was this analysis that led to the decision not to notify the breach to the APD, not dated. Nevertheless, the Contentious Chamber takes into account the fact that the defendant reports having modified its system as of June 26, 2019, while the generation of the document dates from June 18, 2019, thus taking measures.

32 See note 31 above.

Decision on the merits 43/2025 — 26/30

of a nature to eliminate the risk that it necessarily had to identify very quickly.

The Contentious Chamber will take this into account when assessing the sanction it will impose on the defendant.

102. In conclusion and in light of the above, the Contentious Chamber concludes that the defendant could not consider that the violation was not likely to pose a risk to the rights and freedoms of the individuals concerned.³³

103. Therefore, the Contentious Chamber decides that the defendant has committed a breach of Article 33 of the GDPR.

104. Regarding the defendant's reaction towards the complainant following the awareness of the incident, the Contentious Chamber recalls³⁴ that if a letter/email is sent to an incorrect unauthorized recipient (such as to the complainant in this case), it is recommended that the data controller (i.e., the defendant in this case) send a letter/email requesting the erroneous recipient to destroy/delete the letter/email in question and to inform them that they do not have the right to use the data of others communicated by mistake. As the EDPB emphasizes in its Guidelines 01/2021, while many recipients will likely throw the improperly received letter in the trash, in some cases, it is not entirely excluded that the letter may be posted on social media or that the insured party may be contacted. A written confirmation of this deletion/destruction should also be requested, and depending on the sensitivity of the communicated document, the return of the document (a fortiori if it is an original, for example) at the expense of the data controller³⁵. Confirmation that no copy has been made should also be requested.

III. Corrective Measures and Sanctions

105. Under Article 100.1 of the LCA, the Contentious Chamber has the power to:

33 The Contentious Chamber informs the defendant that in its already cited Guidelines 09/2022, the EDPB provides the example below regarding which it indicates that the data breach must be notified (page 36). If these guidelines are subsequent to the reported facts, this has no impact on the assessment made by the SI and followed by the Contentious Chamber. These guidelines merely conform the analysis carried out by the SI at the time of its investigation: "A person calls a bank's call

center to report a data breach. The person in question has received the monthly statement of another person. The data controller conducts a short investigation (i.e., completed within 24 hours), establishes, with a reasonable degree of certainty, that a personal data breach has occurred and reports the potential existence of a systemic flaw implying that other individuals are or could be affected." To the question of whether this security incident should be reported to the competent data protection authority, the EDPB answers in the affirmative.

34 When the data controller notifies the data breach to the DPA, these elements are part of the measures to be notified within the meaning of Article 33.1.d) of the GDPR.

35 See in this regard European Data Protection Board (EDPB), Guidelines 01/2021: Examples regarding the notification of personal data breaches of December 14, 2021, <https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-012021-examples-regarding-personal-data-br each>

Decision on the merits 43/2025 — 27/30

- 1° dismiss the complaint;
- 2° order the dismissal;
- 3° pronounce a suspension of the ruling;
- 4° propose a settlement;
- 5° issue warnings or reprimands;
- 6° order compliance with the requests of the concerned individual to exercise their rights;
- 7° order that the individual be informed of the security issue;
- 8° order the freezing, limitation, or temporary or permanent prohibition of processing;
- 9° order compliance of the processing;
- 10° order the rectification, restriction, or deletion of data and notification of such to the data recipients;
- 11° order the withdrawal of the accreditation of certification bodies;
- 12° impose penalties;
- 13° impose administrative fines;
- 14° order the suspension of cross-border data flows to another State or an international organization;
- 15° refer the case to the Public Prosecutor's Office of Brussels, which will inform it of the follow-up given to the case;
- 16° decide on a case-by-case basis to publish its decisions on the website of the Data Protection Authority.

106. In support of the preceding findings, the Contentious Chamber decides, in accordance with Article 100.1, 5° of the LCA, to issue a reprimand to the defendant for the breach of Articles 12.3 and 15 of the GDPR on the one hand, and a reprimand for the violation of Articles 32 and 33 of the GDPR on the other hand, each of these reprimands sanctioning a distinct behavior.

107. The Contentious Chamber is of the opinion that in each of the cases, this sanction is the one that, in light of all the circumstances of the case at hand and in accordance with the requirements of Article 84 of the GDPR, is appropriate in view of the identified breaches.

108. Regarding the lack of timely response to the complainant's access request (violation of Articles 12.3 and 15 of the GDPR – title II.2), the Contentious Chamber notes, notwithstanding the seriousness of a lack of response within the timeframe to an access request, a fundamental right of the GDPR, a number of specific circumstances related to this case.

Decision on the merits 43/2025 — 28/30

which leads it to consider that not the fine but rather the reprimand constitutes the appropriate sanction in this case.

109. Thus, while the Contentious Chamber did not uphold the arguments put forward by the defendant, who considered - once before the Contentious Chamber - that there had not been a properly submitted request to exercise rights, the Contentious Chamber nonetheless notes that certainly, the request was somewhat buried in a long email sent to a multitude of recipients, which may not have facilitated its identification. The Contentious Chamber particularly notes that upon receiving the reminder of January 21, 2020, the defendant fulfilled its obligation to respond to the complainant's request for access, prior to the filing of the complaint with the Data Protection Authority (DPA)³⁶.

110. The fact that the shortcoming was remedied is taken into account in the choice of reprimand made by the Contentious Chamber, as is the period during which the events occurred, namely in 2019, shortly after the implementation of the GDPR (even though Directive 95/46/EC and the Law of December 8, 1992, on the protection of individuals with regard to the processing of personal data already enshrined this right). The Contentious Chamber also considers the commitment made by the defendant at the time to ensure that its staff was trained to identify requests for the exercise of rights under the GDPR.

111. Regarding the sending of the claim form containing data of a third-party insured to the complainant (Article 32 of the GDPR – Title II.3) and the absence of notification of this data breach to the DPA (Article 33 of the GDPR - Title II.4), the Contentious Chamber also chooses to sanction these past shortcomings with a reprimand rather than a fine, given that it is an uncontested shortcoming that was quickly remedied concerning the violation of Article 32 of the GDPR and a shortcoming that can no longer be remedied concerning Article 33 of the GDPR. The Contentious Chamber also takes into account the period of the events in its choice and the absence at that time of the perspective that exists as of the date of this decision regarding the new obligation to notify data breaches to the DPA.

112. Regarding the shortcomings related to the deletion of data from the CarAttest database and marketing emails (points 13, 17, and 26 above), the Contentious Chamber decides to dismiss them.

36 Notwithstanding the above, the Contentious Chamber regrets having to note that the reasons for which the defendant indicated it had not responded to the complainant's request varied over time, with the defendant blaming the complainant for not having accompanied his request with a copy of his identity card in his email of January 21, 2020, prior to the complainant filing his complaint with the DPA on one hand, and arguing that it had not identified the complainant's request as a request for access, as it was not one according to it, once the complaint was filed with the DPA on the other hand.

Decision on the merits 43/2025 — 29/30

113. In matters of dismissal, the Contentious Chamber is required to justify its decision step by step³⁷ and to:

- pronounce a technical dismissal if the file does not contain or does not contain sufficient elements likely to lead to a sanction or if it has a technical obstacle preventing it from rendering a decision;
- or pronounce a discretionary dismissal if, despite the presence of elements likely to lead to a sanction, the continuation of the examination of the file does not seem appropriate given the priorities of the Data Protection Authority (DPA) as specified and illustrated in its Discretionary Dismissal Policy³⁸.

114. Finally, regarding cases of dismissal based on several grounds, these must be treated in order of importance³⁹.

115. In this case, in the absence of further investigation and findings from the SI regarding them and considering that the Contentious Chamber does not have further elements allowing it to conclude that the defendant has committed a violation of the GDPR in this regard, the Contentious Chamber dismisses these grievances for technical reasons.

IV. Publication of the decision

116. Given the importance of transparency regarding the decision-making process of the Contentious Chamber, this decision is published on the website of the Data Protection Authority (DPA). However, it is not necessary for this purpose that the identifying data of the parties be directly mentioned.

37 Market Court (Court of Appeal of Brussels), September 2, 2020, judgment 2020/AR/329, p. 18.

38 In this regard, the Contentious Chamber refers to its Discretionary Dismissal Policy as developed and published on the website of the Data Protection Authority: <https://www.autoriteprotectiondonnees.be/publications/politique-de-classement-sans-suite-de-la-chambre-contentieuse.pdf>

39 Cf. Title 3 – In what cases is my complaint likely to be dismissed by the Contentious Chamber? of the Discretionary Dismissal Policy of the Contentious Chamber.